

crypto-coverage

Crypto / DeFi Suite Coverage

Preston-Check ships a dedicated crypto-business security suite spanning IDs **P-301 through P-360** — sixty checks organized into six thematic groups covering smart contract security, key custody and storage, outbound transaction safety, inbound asset hygiene, source-wallet integrity, and regulatory compliance.

The suite is informed by current authoritative frameworks: OWASP Smart Contract Top 10 (2025), CryptoCurrency Security Standard v9.0 (December 2024), NIST Cybersecurity Framework 2.0, FATF Recommendation 16 (Travel Rule), MiCA (EU 2024-2026), OFAC sanctions guidance (2024), NIST FIPS 203/204/205 post-quantum standards, OWASP MASVS 2.0, and OWASP API Top 10 (2023). The full source registry with version pins is in `docs/crypto-sources.md`. The framework-to-check mapping for compliance- driven runs is in `docs/crypto-frameworks.md`.

Smart Contract Security (P-301..P-310)

These ten checks target the on-chain attack surface: reentrancy, integer arithmetic safety, authorization patterns, gas-DoS via unbounded loops, DEX slippage, oracle manipulation, token approvals, cross-chain bridge replay protection, stablecoin peg monitoring, and governance time-locks. The catalog mirrors the highest-impact OWASP Smart Contract Top 10 (2025) categories ranked by 2025 financial losses.

ID	NAME	SEVERITY
P-301	Smart Contract Reentrancy Protection	critical
P-302	Integer Overflow Protection (pre-0.8 Solidity)	high
P-303	tx.origin Authorization Anti-Pattern	high
P-304	Unbounded Loops / Gas DoS	medium
P-305	DEX Slippage Protection	high
P-306	Oracle Manipulation Resistance	high

ID	NAME	SEVERITY
P-307	Unbounded Token Approvals	medium
P-308	Bridge Replay Protection	critical
P-309	Stablecoin Peg Monitoring	medium
P-310	Governance Time-Locks on Privileged Operations	high

Key Custody and Storage (P-311..P-320)

The custody group covers private-key handling end-to-end: exposure prevention, hardware-backed signing, KMS integration, MPC and threshold signature schemes, cold-wallet air-gap discipline, hot-wallet concentration caps, key ceremony evidence, seed phrase logging hygiene, key rotation policies, and multi-signature approval workflow discipline.

ID	NAME	SEVERITY
P-311	Private Key / Mnemonic Exposure	critical
P-312	HSM Integration for Production Signing	high
P-313	KMS-Only Key Operations	high
P-314	MPC / Threshold Signature Scheme Usage	medium
P-315	Cold Wallet Air-Gap Discipline	medium
P-316	Hot Wallet Concentration Limits	medium
P-317	Key Ceremony Documentation	low
P-318	Seed Phrase Handling Hygiene	high
P-319	Key Rotation Schedule	medium
P-320	Multi-Sig Approval Discipline	high

Outbound Transaction Safety (P-321..P-330)

This group covers everything between a withdrawal request and the broadcast: address validation, whitelist enforcement, blockchain-analytics risk scoring, OFAC and sanctions screening freshness, community-maintained scam-address checks, address-poisoning detection, mixer / privacy-tool provenance, FATF Travel Rule compliance, new-address cooldowns, and high-value step-up authentication.

ID	NAME	SEVERITY
P-321	Crypto Address Format and Checksum Validation	high
P-322	Withdrawal Address Whitelist Enforcement	high
P-323	Pre-Send Risk Scoring (Blockchain Analytics)	high
P-324	OFAC SDN Live Screening Freshness	high
P-325	Hacker / Scam Address Screening	high
P-326	Address Poisoning Detection	medium
P-327	Mixer / Privacy Tool Provenance Check	high
P-328	Travel Rule Compliance (FATF Recommendation 16)	high
P-329	New-Address Withdrawal Cooldown	medium
P-330	High-Value Transaction Step-Up Authentication	high

Inbound Asset Hygiene (P-331..P-335)

Receiving assets is its own attack surface: dust-attack consolidation risks, scam token honeypots, unverified contract quarantine, NFT phishing patterns, and counterparty reputation pre-checks before crediting balance.

ID	NAME	SEVERITY
P-331	Dust Attack Detection	medium
P-332	Scam / Honeypot Token Detection	medium
P-333	Unverified Contract Quarantine	medium

ID	NAME	SEVERITY
P-334	NFT Phishing and Spam Detection	medium
P-335	Counterparty Reputation Pre-Check	medium

Source Wallet Integrity (P-336..P-340)

Five checks for the funding source itself: multi-hop tainted-funds tracing on incoming flows, behavioral compromise indicators on the wallet account, outstanding-approval audit surfaces in wallet UIs, drainer- pattern detection on signTypedData/Permit/setApprovalForAll signatures, and reorg confirmation depth on credit decisions.

ID	NAME	SEVERITY
P-336	Tainted Funds Source Trace	high
P-337	Wallet Compromise Behavioral Indicators	medium
P-338	Outstanding Token Approval Audit	medium
P-339	Wallet Drainer Pattern Detection	high
P-340	Reorg Confirmation Depth Enforcement	high

Extended Key Storage and Token Semantics (P-341..P-350)

Deeper key-handling controls (hardware wallets, secure enclaves, BIP-44 derivation paths, backup encryption, Shamir's Secret Sharing, in-process memory hygiene) plus token semantics where naive accounting fails (fee- on-transfer, proxy upgrade safety, EIP-2612 Permit replay, ERC-4337 account abstraction).

ID	NAME	SEVERITY
P-341	Hardware Wallet Integration	medium
P-342	Secure Enclave / TPM-Backed Key Storage	high
P-343	BIP-44 Derivation Path Correctness	high

ID	NAME	SEVERITY
P-344	Wallet Backup Encryption At Rest	high
P-345	Shamir's Secret Sharing for Backup Distribution	low
P-346	In-Process Key Memory Hygiene	medium
P-347	Fee-on-Transfer / Rebasing Token Handling	medium
P-348	Proxy Upgrade Safety and Initializer Protection	high
P-349	EIP-2612 Permit Replay Protection	high
P-350	Account Abstraction (ERC-4337) Safety	medium

OWASP / Bybit / PQC / CCSS Closure (P-351..P-360)

The final ten checks close gaps identified by current research: the OWASP Smart Contract Top 10 (2025) categories that aren't in earlier groups (comprehensive access control as the #1 loss category, flash loan attack resistance, unchecked external call returns), the lessons from the Bybit February 2025 cold-to-hot transfer attack (signing- interface verification, blind-signing prevention), DeFi-specific liquidation safety, stablecoin admin freeze handling, CCSS v9.0 compliance evidence verification, emergency pause patterns, and post-quantum cryptography readiness assessment.

ID	NAME	SEVERITY
P-351	Smart Contract Access Control (OWASP SC1:2025)	critical
P-352	Flash Loan Attack Resistance	high
P-353	Unchecked External Call Returns (OWASP SC7:2025)	high
P-354	Cold-to-Hot Transfer Interface Verification	critical
P-355	Blind Signing Prevention	high
P-356	DeFi Liquidation Safety	high
P-357	Token Admin Freeze / Blacklist Handling	medium
P-358	CryptoCurrency Security Standard (CCSS) Evidence	low
P-359	Emergency Pause / Circuit Breaker Pattern	medium

ID	NAME	SEVERITY
P-360	Post-Quantum Cryptography Readiness Assessment	low

Running the suite

To run the full crypto suite against a project:

```
preston-check --config configs/myapp.yml
```

The suite runs as part of every full scan. To run only crypto checks:

```
for n in $(seq 301 360); do
  preston-check --check $(printf '%03d' $n) --config configs/myapp.yml
done
```

To run crypto checks scoped to a specific compliance framework, use the `--framework` flag introduced in v1.1.0:

```
preston-check --framework MiCA           # all MiCA-mapped checks
preston-check --framework "CCSS:9.0:Level2" # CCSS Level 2 controls
preston-check --framework "OWASP-SC-Top-10:2025"
preston-check --framework FATF           # FATF Travel Rule + sanctions
preston-check --framework OFAC
preston-check --framework FIPS           # NIST PQC migration readiness
```

See `docs/crypto-frameworks.md` for the canonical framework-to-check mapping.

Severity distribution

The 60-check crypto suite breaks down as follows by severity: critical (3), high (28), medium (22), low (7). Critical findings are deployment-blockers in CI (use `--ci`); high findings are deployment-blockers for fintech production with regulatory exposure; medium and low findings are improvements that strengthen defense-in-depth without necessarily blocking releases.

Tier and trust tier

All sixty checks default to `min_tier: free` so that crypto businesses of any size can validate their controls without a license. The Pro and Enterprise tiers add value through the audit-package layer (compliance evidence bundling, branded reports, multi-repo dashboard), not by gating the scanning. Trust tier for the full P-301..P-360 range is core (maintainer-authored).

Roadmap

Coverage is comprehensive but additive, and the catalog grows with the threat landscape and the regulatory landscape. Tracked priorities for v1.2+:

- DORA (EU Digital Operational Resilience Act) crypto-asset service provider obligations.
- Solana / Move (Sui, Aptos) language-specific checks; the current smart-contract-focused checks are Solidity-first.
- Bridge-specific replay protection extending P-308 with chain-specific validator-set verification patterns (LayerZero, Wormhole, IBC).
- Post-quantum migration tracking — graduating P-360 from a readiness assessment to specific algorithm checks once FIPS 203/204/205 are routinely deployed.
- MAS TRM (Singapore), APRA CPS 234 (Australia), Reserve Bank of India IT Framework — Asia-Pacific compliance overlays.
- Account abstraction (ERC-4337) as the bundler/paymaster ecosystem matures; expand P-350 with paymaster-specific checks.

Community contributions targeting any of these are welcome via the trust-tier process described in `CONTRIBUTING.md`.